

Two stories defined the week, and they rhymed. A credential-harvesting campaign quietly turned tens of thousands of Fortinet firewalls into open doors, and the U.S. government reached into a private AI lab to switch off — then, six days later, switch back on — its most capable models. Both are stories about trust that was granted and never re-verified: a password, a build pipeline, a model's safeguards. This issue gives each story one verified source, a briefing, and the reason it earned a place.

86,644

FORTINET DEVICES
COMPROMISED

194

COUNTRIES HIT BY
FORTIBLEED

\$4.18B

ACCENTURE OT-
SECURITY DEAL

206

CVES IN JUNE PATCH
TUESDAY

\$3.6B

SALESFORCE-FIN ACQUISITION

6 days

ANTHROPIC FABLE 5 OFFLINE

FortiBleed: 86,644 firewalls, one old mistake

SOURCE [CISA — Hardening Fortinet devices after credential exposure](#) [cisa.gov](#) · 2026-06-18

SUMMARY

Through mid-June, security teams tracked a sprawling campaign — dubbed FortiBleed — against internet-facing Fortinet FortiGate firewalls and SSL-VPN gateways. The operation pulled configuration files from exposed devices, cracked the password hashes stored inside, and assembled verified working administrator credentials. As investigations widened the count climbed from an early 30,000–75,000 devices to 86,644 confirmed across 194 countries by June 19, and on June 18 CISA issued an alert urging every affected organization to act as if already breached.

What makes FortiBleed a textbook information-systems failure is what it is not: there is no new zero-day here. Analysts attribute the campaign to Russian-speaking actors recycling credentials exposed in two earlier Fortinet incidents, combined with poor password hygiene, missing multi-factor authentication, and — the modern accelerant — AI-assisted brute-forcing against weak credential controls. The most trusted box on the network, the perimeter firewall, became the softest entry point precisely because its secrets were old, reused, and unprotected by a second factor.

CISA's guidance is blunt and operational: terminate all active SSL-VPN and administrative sessions, reset every Fortinet VPN and admin password (above all on internet-facing systems), and enforce phishing-resistant MFA. For most enterprises the lesson is uncomfortable and familiar — the appliance is only as strong as its credential lifecycle, and no patch cycle remediates a password that leaked two years ago and was never rotated.

RATIONALE

This is the story of the week because it is simultaneously enormous in scale and elementary in cause — the combination that produces real-world breaches. It crystallizes the single most durable weakness in enterprise security: identity, not unpatched code. A defender who spent the week chasing CVEs would have missed the actual exposure sitting in their own VPN.

It also marks an inflection: the explicit use of AI to accelerate credential attacks at scale. That detail reframes a tired 'rotate your passwords' lesson into a live, compounding threat, and it threads directly into the week's other headline — a government switching off an AI model specifically over its cybersecurity capabilities.

IMMEDIATE ACTION — FORTINET

- ▶ Terminate all active SSL-VPN + admin sessions
- ▶ Reset every Fortinet VPN and admin credential
- ▶ Enforce phishing-resistant MFA on remote access
- ▶ Hunt for unauthorized config changes + new admins
- ▶ Treat internet-facing FortiGate as assume-breach

SECURITY & EXPOSURE

An unpatchable break in Apple's older chips

[usbliter8](#)[BootROM](#)[A12/A13](#)

SOURCE [The Hacker News](#) thehackernews.com · 2026-06-18

SUMMARY

On June 18, researchers at Paradigm Shift published a working exploit and proof-of-concept, [usbliter8](#), that achieves arbitrary code execution inside the SecureROM — the silicon root of trust — of Apple's A12 and A13 chips (and the S4/S5 wearable SoCs). It chains a hardware bug in the Synopsys DWC2 USB controller with a firmware configuration flaw to compromise the boot chain before Apple's signed code ever loads. Because BootROM is burned into the silicon at manufacture, no software update can ever fix it; affected devices carry the flaw for life.

The practical risk is bounded. This is not a remote attack: it requires physical possession, the device in DFU mode, and a USB connection to a dedicated RP2350 microcontroller board, after which the exploit finishes in under two seconds. Crucially, the researchers do not demonstrate a Secure Enclave compromise — Apple's separate protection boundary holds — though they warn BootROM-level control opens new routes to attack it. It is, in spirit, the successor to 2019's [checkm8](#).

RATIONALE

Unpatchable root-of-trust breaks are rare and consequential, and this one lands cleanly in the reporting window with coordinated disclosure. It matters for mobile-device forensics, for high-risk users and enterprises with older fleets, and as a reminder that 'secure boot' is a lifecycle property of hardware that ages — selected over louder but lower-substance breach headlines because its impact is permanent.

Accenture's \$4.18B bet on OT security

[M&A](#)[Dragos](#)[runZero](#)[NetRise](#)[SOURCE](#)[SecurityWeek](#) securityweek.com · 2026-06-19

SUMMARY

Accenture announced on June 19 that it will take a majority stake in Dragos and fully acquire runZero and NetRise in a roughly \$4.18 billion push into operational-technology (OT) security. The deal values Dragos — the vendor-neutral leader in industrial threat detection — at about \$3.25 billion; runZero (founded by Metasploit creator HD Moore) contributes asset discovery and exposure assessment, while NetRise adds firmware analysis and software-supply-chain visibility. The three are projected at ~\$208 million ARR, up 53% year over year, and will operate under Dragos with closings expected in August and September.

Accenture framed the move around defending critical infrastructure — power grids, manufacturing, data centers — in an age of AI-driven threats and geopolitical risk. The logic is that securing industrial systems requires knowing exactly what hardware and firmware is on the network, a visibility most enterprises lack for their OT estate.

RATIONALE

This is the largest OT/ICS security consolidation to date and a clear signal that industrial cybersecurity has moved from niche to strategic. It also shows the integrator model absorbing best-of-breed asset-discovery and firmware tooling — exactly the capabilities FortiBleed and the Red Hat npm worm exploit the absence of. Chosen because it connects the week's incident stories to where defensive budgets are actually moving.

A worm in Red Hat's npm packages

[Supply chain](#)[npm](#)[OIDC](#)[SLSA](#)[SOURCE](#)[Wiz Research](#) wiz.io · 2026-06

SUMMARY

A supply-chain compromise hit the @redhat-cloud-services npm namespace: 96 versions across 32 packages — cumulatively ~117,000 weekly downloads — were trojanized. The root cause was a compromised Red Hat employee GitHub account, used to push malicious orphan commits that bypassed code review entirely, then trigger GitHub Actions workflows to mint OpenID Connect (OIDC) tokens and publish the tampered packages — complete with valid SLSA provenance attestations.

The payload, named Miasma, is a credential-stealing worm closely resembling 'Mini Shai-Hulud,' a supply-chain malware whose code was publicly released by the group TeamPCP. That open-sourcing is the sting in the tail: even if the original operators move on, the technique is now a template any competent actor can adapt.

RATIONALE

It is the cleanest illustration this month of how modern supply-chain attacks actually work — not a clever exploit but a stolen identity plus an abused CI/CD pipeline, with provenance signatures that look legitimate because, cryptographically, they are. Selected because 'valid SLSA provenance on malicious packages' upends a control many teams treat as sufficient.

Patch Tuesday: 206 fixes, two 9.8 RCEs

[CVE-2026-45657](#)[CVE-2026-47291](#)[CVE-2026-49160](#)[SOURCE](#) [SOCRadar](#) [socradar.io](#) · 2026-06-09

SUMMARY

Microsoft's June 9 release addressed 206 vulnerabilities, including three publicly disclosed zero-days and 37 criticals. The two that should top any remediation queue are unauthenticated remote-code-execution flaws rated CVSS 9.8: CVE-2026-45657 in the Windows kernel and CVE-2026-47291 in HTTP.sys, both exploitable with no user interaction. A third zero-day, CVE-2026-49160, is an HTTP/2 'bomb' denial-of-service condition.

The pairing of network-reachable, no-interaction RCEs with a protocol-level DoS makes this a month where patch latency translates directly into exposure for any internet-facing Windows service.

RATIONALE

It is the baseline hygiene event of the month, and the two 9.8 unauthenticated RCEs are wormable-class — the kind of flaw that turns into an incident if a maintenance window slips. Included as foundational even though it lands just outside the seven-day window, because it sets the patch backdrop the rest of the week's exploitation occurs against.

Check Point VPN zero-day, exploited by ransomware

[CVE-2026-50751](#)[KEV](#)[VPN](#)[SOURCE](#) [Rapid7](#) [rapid7.com](#) · 2026-06

SUMMARY

CVE-2026-50751, an authentication-bypass in Check Point Remote Access VPN and Mobile Access, was exploited in the wild as a zero-day, letting unauthenticated attackers establish a VPN session. CISA added it to the Known Exploited Vulnerabilities catalog and set a June 11 remediation deadline for federal civilian agencies; ransomware crews were among the earliest to weaponize it.

Coming alongside FortiBleed and continued exploitation of a Cisco Catalyst SD-WAN flaw (CVE-2026-20182), it completes a clear pattern: the remote-access edge is the front line, and VPN appliances are where 2026's intrusions begin.

RATIONALE

Chosen to reinforce the cover story's thesis with a second, independent data point: edge and VPN devices are the season's primary intrusion vector, and a KEV listing with a federal deadline is as close to a regulator saying 'now' as security gets.

AI & GOVERNANCE

Washington switched off two AI models — then let one back

Export controls Anthropic Fable 5 Mythos 5

SOURCE [AI Jazeera](#) [aljazeera.com](#) · 2026-06-13

SUMMARY

On June 12–13, the U.S. Commerce Department issued a national-security export-control directive barring access to Anthropic's two most capable models — Fable 5 and Mythos 5 — by any foreign national, whether inside or outside the United States, including the company's own non-citizen employees. With no compliant way to segment access overnight, Anthropic disabled both models for every customer worldwide; lesser models such as Claude Opus 4.8 stayed online. Officials pointed to a claimed technique for bypassing Fable 5's safeguards around Mythos's cybersecurity capabilities; Anthropic countered it had seen only 'verbal evidence' of a narrow jailbreak it argued exists in rival models too.

Six days later, on June 18, Anthropic restored Fable 5 — but a changed one. The returned model ships with nationality-based access controls, enhanced identity verification at API onboarding, and stricter safety classifiers that increasingly route prompts touching cybersecurity, chemistry, and biology to Opus 4.8. The episode is the sharpest point yet in a running conflict: Trump ordered federal agencies off Anthropic in February 2026, and the Pentagon has labeled the company a 'supply-chain risk,' a designation Anthropic is contesting in court.

RATIONALE

This sets a precedent information-systems leaders cannot ignore: a frontier model is now treated as a dual-use export item the state can switch off without notice, and switch back on only with nationality-gated controls bolted into the API. Any architecture that hard-depends on a single frontier model now carries political-availability risk alongside the usual uptime risk.

It earns AI billing over the week's product launches because it is not about a capability but about control — who may hold advanced AI, enforced through export law rather than a terms-of-service page. That is the more consequential development.

ENTERPRISE & INNOVATION

Salesforce buys Fin (née Intercom) for \$3.6B

[Agentic AI](#)[M&A](#)[Agentforce](#)[SOURCE](#)[TechCrunch](#)

techcrunch.com · 2026-06-15

SUMMARY

On June 15 Salesforce agreed to acquire Fin — the AI customer-service company formerly known as Intercom — for about \$3.6 billion. Fin's agent handles support conversations end to end across live chat, email, phone, WhatsApp, SMS, and Slack, and Salesforce says it resolves roughly 76% of incoming requests with no human in the loop. The deal brings more than 30,000 business customers and is slated to fold into Agentforce, Salesforce's platform for building custom enterprise AI agents; it is expected to close in Q4 FY27.

It lands amid a broader shift in how enterprises buy agentic AI — toward fixed 'agentic license' agreements and away from the consumption-metered pricing vendors floated in 2025.

RATIONALE

The week's largest enterprise-software deal, and a marker of consolidation in the customer-service agent layer — the first place agentic AI is delivering measurable labor substitution. Chosen because the 76%-autonomous-resolution figure is the kind of hard number that moves enterprise strategy, not just headlines.

HPE bets on hybrid quantum with eight partners

[Quantum](#)[HPC](#)[HPE Discover](#)[SOURCE](#)[The Quantum Insider](#)

thequantuminsider.com · 2026-06-16

SUMMARY

At HPE Discover on June 15, Hewlett Packard Enterprise expanded research relationships with eight companies — Intel, IQM, Qblox, Quantinuum, QuEra, Quantum Machines, Rigetti, and Riverlane — to integrate quantum systems with its Cray supercomputing platform for practical hybrid classical-quantum workflows. Notably, HPE declined to bet on a single qubit technology, working instead across neutral-atom, ion-trap, superconducting, and silicon-spin approaches.

The focus is unglamorous but real: integrated testbeds, software interoperability, and benchmarking workloads that span HPC, AI, and quantum — the plumbing that has to exist before enterprises can run quantum anything in production.

RATIONALE

Enterprise quantum is mostly hype, which is exactly why an architecture-neutral, HPC-anchored, integration-first bet from a major vendor is worth flagging — it is a roadmap, not a press release. It also pairs with this issue's horizon item: the same organizations planning hybrid quantum should already be inventorying their cryptography.

AI is now building the chips: Nvidia × TSMC

cuLitho

Omniverse

Semiconductors

SOURCE

[NVIDIA Newsroom](#) nvidianews.nvidia.com · 2026-06

SUMMARY

Nvidia and TSMC detailed how AI is moving into chip manufacturing itself. TSMC is deploying Nvidia's cuLitho for computational lithography — claiming a 20–50% improvement in cost-effectiveness or cycle time versus CPU-based methods — and exploring an Omniverse-based 'FabTwin' to simulate fab layouts and manufacturing workflows in a virtual environment before committing physical capacity.

The significance is structural: the AI boom is both the demand that strains semiconductor supply and, increasingly, the tool used to expand and optimize that supply — a flywheel between the chips and the software that designs and makes them.

RATIONALE

Selected as the innovation throughline because it is the rare story that is upstream of everything else in the issue — every FortiGate, every AI model, every quantum control system ultimately depends on fab output. It is marginally older than the seven-day window, included for its structural weight rather than its freshness.

POLICY & HORIZON

The EU AI Act's enforcement clock is running

EU AI Act

GPAI

Compliance

SOURCE

[EU AI Act tracker \(artificialintelligenceact.eu\)](#) artificialintelligenceact.eu · 2026-06

SUMMARY

The EU AI Act's enforcement powers over general-purpose AI providers switch on August 2, 2026, and the final GPAI Code of Practice is due in June — putting providers on a tight clock to document training data, systemic-risk mitigations, and transparency. A 2026 amendment package, the 'Digital Omnibus,' was politically agreed in mid-June but not yet formally adopted, leaving some obligations in flux even as the deadline approaches.

For multinationals the practical question is no longer whether the Act applies but how to evidence compliance across models that may also be subject to U.S. export controls — two regulatory regimes now bearing on the same systems.

RATIONALE

Regulation rarely makes a weekly, but a hard enforcement date six weeks out, colliding with U.S. export-control actions on the very same models, is a genuine planning event. Chosen to give the compliance and architecture implications of the Anthropic story their proper frame.

Horizon risk: harvest now, decrypt later

Post-quantum

CNSA 2.0

HNDL

SOURCE

[Cloud Security Alliance](#)

labs.cloudsecurityalliance.org · 2026-06

SUMMARY

Adversaries are already archiving encrypted traffic today to decrypt once quantum hardware matures — the 'harvest now, decrypt later' threat — which means data with a long secrecy lifetime may effectively be compromised the moment it crosses the wire. The NSA's CNSA 2.0 suite requires national-security systems to support post-quantum algorithms for new acquisitions from January 1, 2027, and enterprise migration is realistically a 5–15 year program.

The first concrete step is unglamorous: a cryptographic inventory — knowing where, and with what algorithms, you encrypt — which most organizations have never compiled.

RATIONALE

It is the long-fuse risk that pairs naturally with HPE's quantum push and rounds out the issue's arc from today's credential theft to tomorrow's cryptographic reckoning. Included so the handbook closes on something to start now, not just this week's fires.

CROSS-CURRENTS — THE THREADS UNDERNEATH

One current runs through almost every story: artificial intelligence is now the weapon, the target, and the contested strategic asset at once. FortiBleed used AI to weaponize old credentials; Washington pulled Anthropic's Mythos specifically over its cybersecurity capabilities; the EU and U.S. are racing to write the rules of who may hold such capability at all. The same technology pushing Nvidia into TSMC's fabs is the technology regulators now treat as a munition.

A second thread is the stubborn weakness of identity and provenance. FortiBleed (reused credentials, no MFA), the Red Hat npm worm (a stolen developer account and abused CI tokens), and the Klue-style OAuth-token thefts seen this week are the same failure in different costumes — trust extended to a credential or a pipeline that was never independently verified. As agentic AI is bought wholesale and wired into the enterprise, that unverified trust surface only grows; Accenture's \$4.18B OT bet is the market pricing exactly that risk.

Put together, the year's defining information-systems question is shifting from 'are we patched?' to 'can we prove the provenance of every identity, dependency, and model we depend on — and do we still control it if a government, or an attacker, decides we don't?'

IT & INFOSEC MANAGER'S CHECKLIST

- 1 Fortinet: terminate sessions, rotate all VPN/admin credentials, enforce phishing-resistant MFA.
- 2 Apply June Patch Tuesday — prioritize the two 9.8 RCEs (CVE-2026-45657, -47291) and the HTTP/2 DoS.
- 3 Confirm CVE-2026-50751 (Check Point) and CVE-2026-20182 (Cisco SD-WAN) are remediated.
- 4 Audit npm for @redhat-cloud-services; pin versions and don't trust provenance alone.
- 5 Harden CI/CD: scope OIDC tokens, require review on every publish, alert on orphan commits.
- 6 Inventory older Apple A12/A13 devices in high-risk roles; treat physical access as game-over.
- 7 Kill credential reuse and rotate OAuth tokens for integrated SaaS (Salesforce, Gong, etc.).
- 8 Map model-availability risk: have a contingency if a frontier model is export-restricted overnight.
- 9 Begin a cryptographic inventory toward post-quantum / CNSA 2.0 readiness.
- 10 Scope EU AI Act / GPAI exposure ahead of the August 2 enforcement date.

METHOD & VERIFICATION

Every story carries a single source link that was checked to resolve (HTTP 200) from a highly-credible outlet within the reporting window. Summaries are written for a reader with roughly a day's background in the topic; rationales explain selection. Where a primary source rate-limited automated checks, a verified equivalent of equal credibility was substituted.